J&J ACELERAÇÃO CYBERSECURITY

Identidades Não Humanas (NHI): Casos Práticos e Resoluções

Um guia de arquitetura focando nas microtarefas de descoberta, limites, criptografia, nuvem e ciclo de vida.

Edição de Estudo

Gemini Notebook

[STATUS: PENDENTE]

Microtarefa 1: Desafio de Descoberta

Objetivo: Identificar e mapear NHIs (Non-Human Identities) em um ambiente corporativo.

- Liste três programas que agem sem interação humana em uma empresa.
  - Para cada um, indique:
    - O recurso acessado.
    - A ação necessária.
    - A equipe que deveria responder pelo acesso.

Gemini Notebook

[STATUS: BLUEPRINT VERIFICADO]

Resolução da Microtarefa 1: Matriz de Inventário de Inventário de Identidades

Programa (Workload)	Recurso Acessado	Ação Necessária	Equipe Responsável (Owner)
`Processo Noturno de Conciliação`	Banco de Dados de Vendas	Leitura e Escrita (Consolidação)	Equipe de Engenharia de Dados
`Pipeline CI/CD (Deploy)`	Ambiente de Produção (Servidores)	Publicação de nova versão (Artefatos)	Equipe de DevOps/Plataforma
`Bot de Atendimento/Alertas`	API do Slack/Teams e Fila de Chamados	Postar mensagens de erro operacionais	Equipe de SRE/Operações

Gemini Notebook

02 Microtarefa 2 questiona a diferença entre localizar uma identidade e comprovar sua autenticidade.

DESAFIO_ANALITICO

Classifique os cinco artefatos abaixo:

- Nome de conta
- Senha de banco
- client_id
- Token de acesso
- Chave privada

PERGUNTAS_DIRETRIZES

1. Quais destes itens precisam ser protegidos estritamente como segredos?
2. Quais ajudam apenas a localizar uma identidade, mas não demonstram sozinhos sua autenticidade?

Gemini Notebook

O vocabulário separa elementos de localização pública de credenciais que exigem proteção rigorosa.

IDENTIFICADORES PÚBLICOS (Apenas localizam)

Nome de conta, client_id

DEFINIÇÃO OPERACIONAL:

Apontam para um objeto no diretório. Sozinhos, não provam quem está do outro lado da conexão. Podem transitar em logs e configurações.

SEGREDOS (Exigem proteção / Comprovam autenticidade)

Senha de banco, token de acesso, chave privada

DEFINIÇÃO OPERACIONAL:

Valores confidenciais cuja exposição permite que um invasor atue em nome da aplicação. Nunca devem ser expostos em URLs, logs ou código.

Gemini Notebook

03

Microtarefa 3 avalia o risco residual quando credenciais temporárias dependem de um segredo estático.

RELATO DE ARQUITETURA

- Cenário Atual: Uma automação foi configurada para utilizar um token de acesso com duração de **15 minutos**.
- A Condição: Para obter e renovar este token, o código da apicação mantém armazenada uma **chave permanente**.

Qual é o risco operacional que ainda existe nesta configuração?

Que alternativa técnica você investigaria para eliminar esse risco?

Que evidência provaria a viabilidade técnica da alternativa escolhida?

Gemini Notebook

A dependência de chaves estáticas mantém um ponto único de falha de longa duração.

[RISCO RESIDUAL]	A chave permanente continua sendo o ponto único de falha. A validade curta do token é inútil se um invasor roubar a chave raiz, pois ele poderá gerar infinitos tokens novos.
[ALTERNATIVA TÉCNICA]	Implementar mecanismos que não exigem gestão direta do segredo, como Identidades Gerenciadas (ex: Azure Managed Identities, AWS IAM Roles) ou Federação de Workload (OIDC).
[EVIDÊNCIA REQUERIDA]	Demonstrar que o workload consegue autenticar-se e obter o token diretamente através da infraestrutura subjacente, provando a inexistência de credenciais hardcoded no repositório.

Gemini Notebook

[STATUS: PENDENTE]

Microtarefa 4: Limites do OAuth 2.0

Objetivo: Definir limites estritos para acesso máquina-a-máquina utilizando o framework OAuth 2.0.

- Um serviço só precisa consultar a disponibilidade de estoque.
- Descreva a audience e um scope apropriados para este cenário.
- Cite uma operação que a API deverá negar mesmo que o token apresentado seja válido.

Gemini Notebook

Resolução da Microtarefa 4: Parâmetros e Restrições OAuth

[STATUS: BLUEPRINT VERIFICADO]

Parâmetros do Token (Autorização)

- **Destinatário (aud): api-estoque**

  Garante que o token só seja aceito pela API de estoque, evitando reutilização indevida em outras APIs.

- **Escopo (scope): estoque.ler_disponibilidade**

  Aplica o princípio do menor privilégio. Concede apenas leitura de status, sem acesso a preços ou dados sensíveis.

Operações Negadas pela API

- A API **DEVE NEGAR** (HTTP 403 Forbidden) tentativas de:
  - **POST**, **PUT** ou **DELETE** (ex: **estoque.atualizar_quantidade**)
  - Leituras fora do escopo delimitado (ex: **estoque.ler_custo_produto**)

Nota Arquitetural: A assinatura e a validade do token não substituem a política de autorização local do recurso.

Gemini Notebook

05

Microtarefa 5 desafia a falsa sensação de segurança ao inspecionar visualmente tokens no formato JWT.

CENÁRIO PRÁTICO

Um desenvolvedor afirma que a integração está segura porque “conseguiu abrir o JWT recebido colando-o em um site decodificador e verificando as regras”.

Por que “abrir” ou “ler” o conteúdo de um JWT em um site não comprova absolutamente a sua validade perante a API?

Quais são os riscos críticos que surgem ao colar um token real (de ambiente de produção) em uma fermenta de tercer, na internet?

Gemini Notebook

Decodificar texto em Base64url não atesta validade criptográfica, proteção ou adequação do escopo.

Por que não comprova validade? (O Fato Técnico)

Base64url != Criptografia

- O formato padrão do JWT é apenas texto codificado, legível por design.

- Ler os campos (iss, aud, scope) não garante que a assinatura criptográfica (signature) é autêntica ou que o token não expirou.

- O token pode ser uma falsificação bem formatada.

Os Riscos do Decodificador Externo (O Risco Operacional)

- Exposição de Dados Sensíveis: O corpo do JWT pode conter dados internos da arquitetura (IDs, papéis) que vazam para terceiros.

- Sequestro de Sessão (Token Hijacking): Se o token colado ainda estiver dentro do prazo de expiração (exp), o site (ou um atacante interceptando a rede) pode utilizá-lo para acessar a API legítima em nome da sua aplicação.

06

Microtarefa 6 questiona a ilusão de que a simples troca de senha encerra a resposta a um incidente.

LOG DE INCIDENTE
Evento: Ocorre o vazamento confirmado de uma credencial estática de serviço.
Ação Tomada: A equipe de infraestrutura troca a senha afetada e declara o incidente "Fechado" no sistema de chamados.

Que etapas operacionais cruciais foram ignoradas em relação a tokens já emitidos, manutenção de permissões, trilhas de dados e continuidade do negócio?

Gemini Notebook

A resposta operacional integral exige auditar sessões ativas, integridade de permissões e resiliência.

[ ]	1. Invalidação de Tokens Existentes: Trocar a senha raiz não bloqueia automaticamente os JWTs gerados minutos antes. É necessário revogar sessões ativas ou aguardar a expiração, validando a efetividade do bloqueio na API.
[ ]	2. Investigação de Permissões (Backdoors): Verificar se a chave vazada tinha privilégios suficientes para que o atacante criasse novas chaves ocultas, contas paralelas ou escalasse privilégios.
[ ]	3. Auditoria de Exfiltração: Analisar os logs (access logs/audit logs) para mapear retroativamente quais dados exatos foram lidos, alterados ou extraídos durante a janela de exposição.
[ ]	4. Validação de Continuidade: Confirmar se todos os consumidores legítimos da chave anterior (cron jobs, outros microsserviços) foram notificados e atualizados, garantindo que a 'correção' não derrubou operações essenciais de negócio.

Gemini Notebook

[STATUS: PENDENTE]

Microtarefa 7: Isolamento Criptográfico

Objetivo: Analisar os riscos do compartilhamento de segredos em implementações mTLS/Certificados e desenhar a segregação.

- Se dois serviços compartilham a mesma chave privada e certificado:
  - Que dificuldades surgem para a auditoria?
  - Que dificuldades surgem para o bloqueio de apenas um deles?
- Proponha como separar a responsabilidade.

Gemini Notebook

Resolução da Microtarefa 7: O Risco do Compartilhamento e a Segregação

[STATUS: BLUEPRINT VERIFICADO]

Problemas do Compartilhamento (Riscos)

- **Auditoria Comprometida:** Os logs exibirão a mesma identidade. É impossível distinguir qual serviço executou uma ação maliciosa ou gerou um erro.
- **Bloqueio Destrutivo (*Blast Radius*):** Revogar a chave compartilhada para conter um serviço comprometido derrubará o serviço legítimo instantaneamente.

Solução Proposta (Separação de Responsabilidade)

- **Isolamento de Chaves:** Emitir certificados distintos, atrelados a chaves privadas exclusivas para cada workload.
- **Mapeamento Estrito:** Mapear cada certificado para permissões específicas no servidor de recursos (ex: **svc-relatorios** e **svc-faturamento** ganham identidades próprias e acessos segregados).

Gemini Notebook

[STATUS: PENDENTE]

Microtarefa 8: Identidades em Nuvem

Objetivo: Mapear os conceitos nativos de identidade em um ecossistema de nuvem pública.

- Escolha uma das três nuvens principais (AWS, Azure ou Google Cloud) e explique:
  - Qual é a identidade?
  - Quem pode utilizá-la?
  - Como obtém credenciais?
  - Onde ficam definidas as permissões sobre o recurso?

Gemini Notebook

Resolução da Microtarefa 8: Perfil de Identidade Cloud (AWS)

[STATUS: BLUEPRINT VERIFICADO]

Nuvem Escolhida: AWS (Amazon Web Services)

A Identidade `IAM Role` Uma identidade assumível, que não possui credenciais estáticas ou permanentes próprias.	Quem pode utilizá-la Determinada pela `Trust Policy` (Política de Confiança). Pode ser assumida por serviços da AWS (ex: EC2, Lambda), workloads federados (via OIDC), ou usuários específicos.
Como obtém credenciais O serviço invoca o `AWS STS` (Security Token Service), que devolve credenciais temporárias de sessão (Access Key ID, Secret Key e Session Token) com validade curta.	Onde ficam as permissões Definidas nas `IAM Policies` (Políticas de Permissão) anexadas à `Role`, ou através de `Resource-based Policies` anexadas diretamente ao recurso (ex: S3 Bucket Policy).

Gemini Notebook

09

Microtarefa 9 exige aplicar o Princípio do Menor Privilégio transcrevendo requisitos de negócio em testes práticos.

USER PROFILE DIAGNOSTIC

Entidade: Automacao_Bot

Finalidade: Abrir chamados de falha

GLOBAL ADMIN

DIAGNOSTIC PROMPT 1:

Escreva uma “Necessidade de Negócio Verificável” que restrinja esta automação.

DIAGNOSTIC PROMPT 2:

Defina um Papel Mínimo (Role) adequado.

DIAGNOSTIC PROMPT 3:

Desenhe três cenários de “Testes Negados” (Negative Tests) que provariam que o limite de acesso está funcionando.

Gemini Notebook

O design de RBAC mapeia a necessidade estrita para o escopo, comprovando seus limites através de falhas intencionais.

NECESSIDADE VERIFICÁVEL

O bot requer permissão apenas para gravar/criar novos registros de falha estritamente na fila de Operações.

PAPEL MÍNIMO (ROLE)

Criador de Chamados (Ticket_Creator) associado unicamente ao escopo Fila: Operações.

Test 1: Tentar executar uma chamada de leitura (GET) na fila de Recursos Humanos. **[NEGADO]**

Test 2: Tentar realizar a exclusão (DELETE) de um chamado recém-criado. **[NEGADO]**

Test 3: Tentar alterar parâmetros de permissão (UPDATE) ou ler as variáveis de usuários do sistema. **[NEGADO]**

Gemini Notebook

10

Microtarefa 10 explora o dilema operacional do desligamento de contas de sistema que parecem "silenciosas".

```
DIAS_DESDE_ULTIMO_LOGIN: 60
```

Cenário Operacional: Uma conta de serviço não registra atividades nos logs centrais há exatos 60 dias. A equipe de infraestrutura propõe a delegação imediata para economizar licenças.

Antes da exclusão irreversível, que dependências ocultas e rotinas de sazonalidade técnica você deve investigar?

Como você deve registrar e documentar formalmente a decisão para resguardar a operação e a auditoria?

Gemini Notebook

O desprovisionamento seguro substitui exclusões abruptas por investigação de sazonalidade e retenção de estado (Soft Delete).

1. Investigar a Sazonalidade Oculta:
O silêncio pode ser design. Mapear execuções de fechamento contábil (trimestral/anual), cron jobs pontuais, renovações de certificados ou integrações passivas de terceiros que não dependem de log diário.

2. Aplicar a Desativação Reversível (Soft Delete):
Suspender ou revogar as chaves localmente (desativar credencial) antes de excluir o objeto/identidade do diretório. Permitir que o serviço falhe de forma controlada.

3. Registrar o Log de Decisão (Ownership):
Documentar em um ticket formal: A hipótese inicial de inatividade, o Owner de negócio que aprovou a remoção e o arquivamento das permissões originais para caso de um rollback emergencial.

Gemini Notebook

[STATUS: PENDENTE]

Microtarefa 11: Rotação de Credenciais

Objetivo: Planejar a rotação de segredos com zero downtime (sem interrupção de serviço).

- Escreva um plano de troca para um robô que executa a cada hora e não pode perder pedidos.
- Defina:
  - Teste de continuidade.
  - Teste de rejeição da credencial anterior.
  - Condição de interrupção segura (rollback).

Gemini Notebook

Resolução da Microtarefa 11: Plano de Rotação (Zero Downtime)

[STATUS: BLUEPRINT VERIFICADO]

Plano de Troca (Cronograma)

1. **Geração:** Criar a `Credencial B` no provedor, mantendo a `Credencial A` ativa (período de sobreposição).
2. **Entrega:** Inserir a Credencial B no cofre de segredos da aplicação consumidora.
3. **Atualização:** Reiniciar ou atualizar o robô na janela entre as execuções horárias, forçando-o a assumir a Credencial B.

Checklist de Validação e Segurança

[ ] Teste de Continuidade: Observar a próxima execução horária e confirmar o sucesso nos logs da aplicação e da API (HTTP 200/201).

[ ] Teste de Rejeição: Revogar a Credencial A. Simular uma chamada com ela e confirmar o bloqueio imediato no servidor de recursos (HTTP 401 Unauthorized).

[ ] Condição de Interrupção (Rollback): Se a Credencial B falhar nos testes iniciais, o plano é interrompido antes da revogação da chave A. O robô é revertido imediatamente para a Credencial A provisória.

Gemini Notebook

12

Microtarefa 12 confronta a falsa equivalência de segurança entre remover chaves do código e gerenciar segredos em execução.

ENV_VARS=true

Alegação do Time de Desenvolvimento:
Desenvol/mmnto: “Nossas chaves estáticas de produção estão perfeitamente protegidas, pois removemos tudo dos arquivos de repositório e injetamos via Variáveis de Ambiente no servidor.”

Quais perguntas incisivas você faria ao time focado em Origem, Exposição em Leitura, Logs e Mecânica de Renovação para expor a insuficiência desta arquitetura?

Gemini Notebook

Variáveis de ambiente não fornecem a **auditoria**, a **criptografia** e o **isolamento de memória** de um cofre de segredos estruturado.

[ORIGEM] Quem ou o quê injeta essa variável no SO antes da aplicação iniciar? Se for um script de pipeline, a chave continua vazada em outro lugar?	**[LEITURA E SUBPROCESSOS]** Se a aplicação executar um subprocesso ou usar ferramentas de debug na mesma máquina, qualquer processo vizinho consegue despejar (dump) o ambiente e ler o segredo?
[COMPORTAMENTO DE LOGS] Quando ocorre uma falha fatal (crash/stack trace), a infraestrutura (ex: Kubernetes/Docker) ou a aplicação imprimem de forma indiscriminada todo o bloco .env no log centralizado?	**[ROTINA DE RENOVAÇÃO]** Como vocês giram (rotação) esta chave em tempo real com zero downtime sem a funcionalidade de renovação nativa de um Secrets Manager?

Gemini Notebook